

Security Risk Assessment : Definitions

National Institute of Standards and Technologies (NIST) introduces **risk management** as “the process of **identifying risk**, **assessing risk**, and **reduce risk** to an acceptable level”.

This process is developed to **mitigate security losses** of systems and **analyze risks correctly** with optimum and reasonable cost.

The assessment of risk can be expressed **qualitatively** or **quantitatively**.

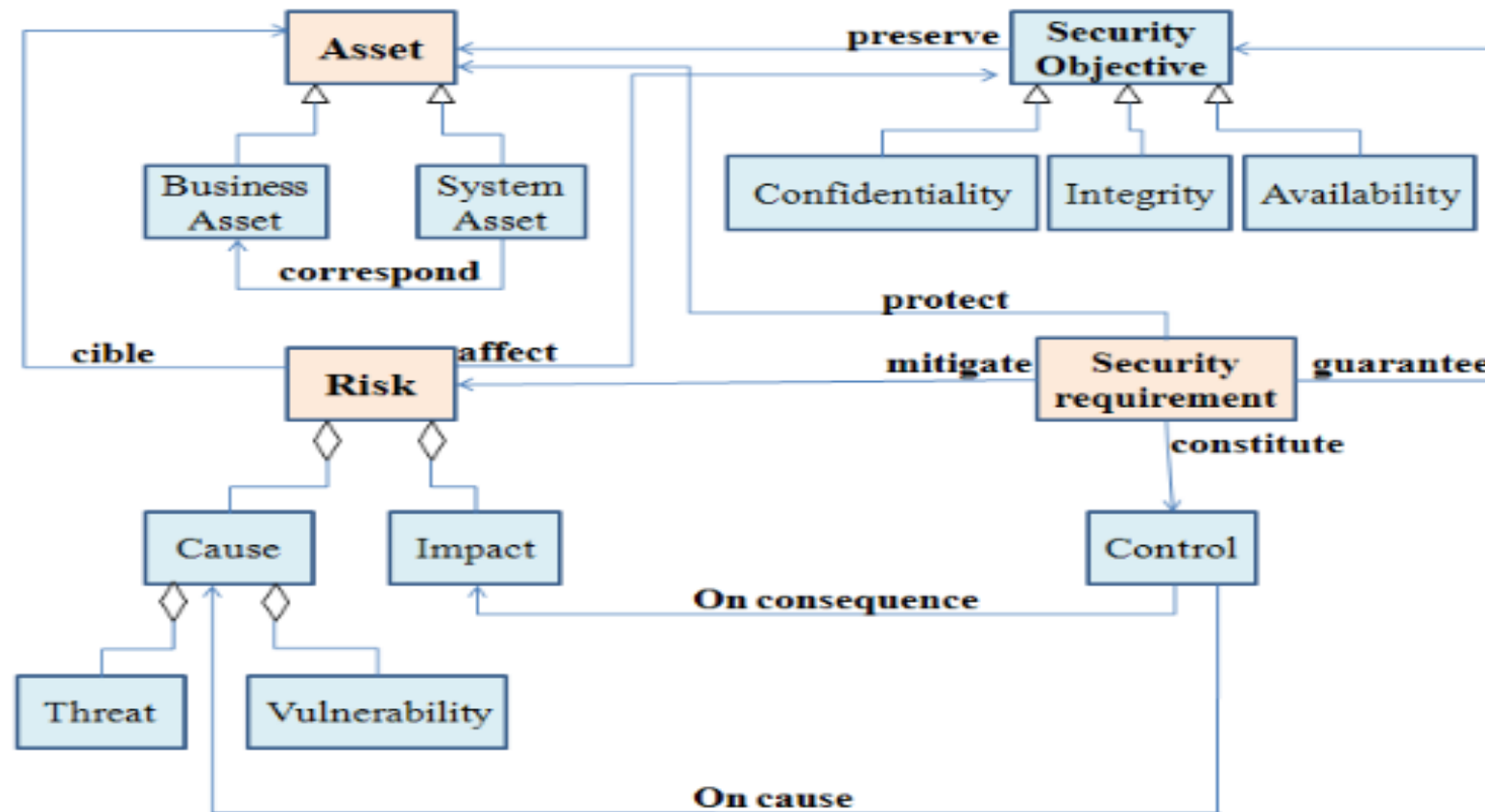
In **qualitative models**, the risk is defined as the probability of events using descriptors as low, moderate or high.

In **quantitative models**, the risk is defined as the probability of events using numerical values.

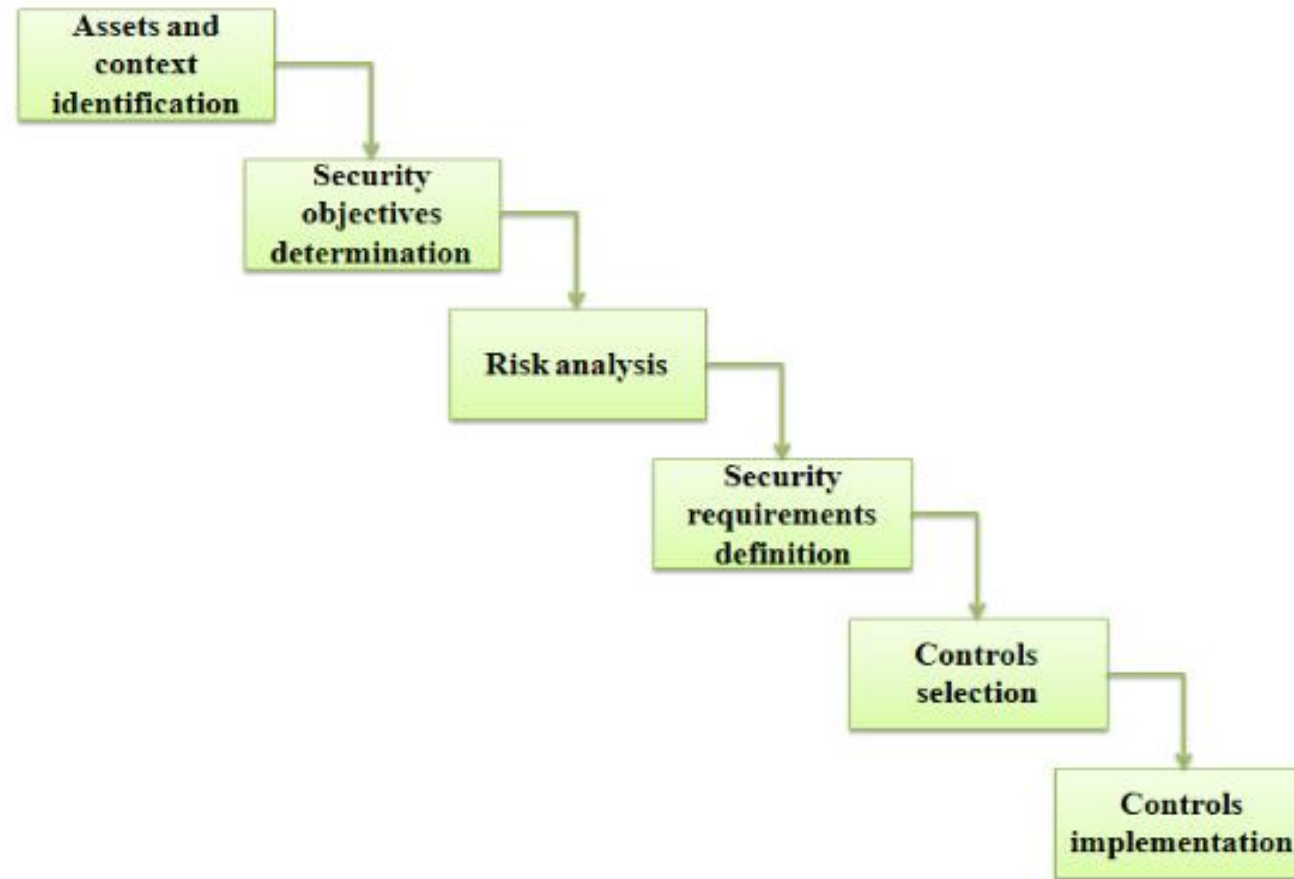
Qualitative risk assessment models give **subjective** and **inconsistent** results of security losses due to the lack of mathematical and statistical metrics for measuring the risks.

Quantitative security risk assessment models give **objective** and **consistent calculation** of security losses by using metrics crucial to cost-benefit decisions.

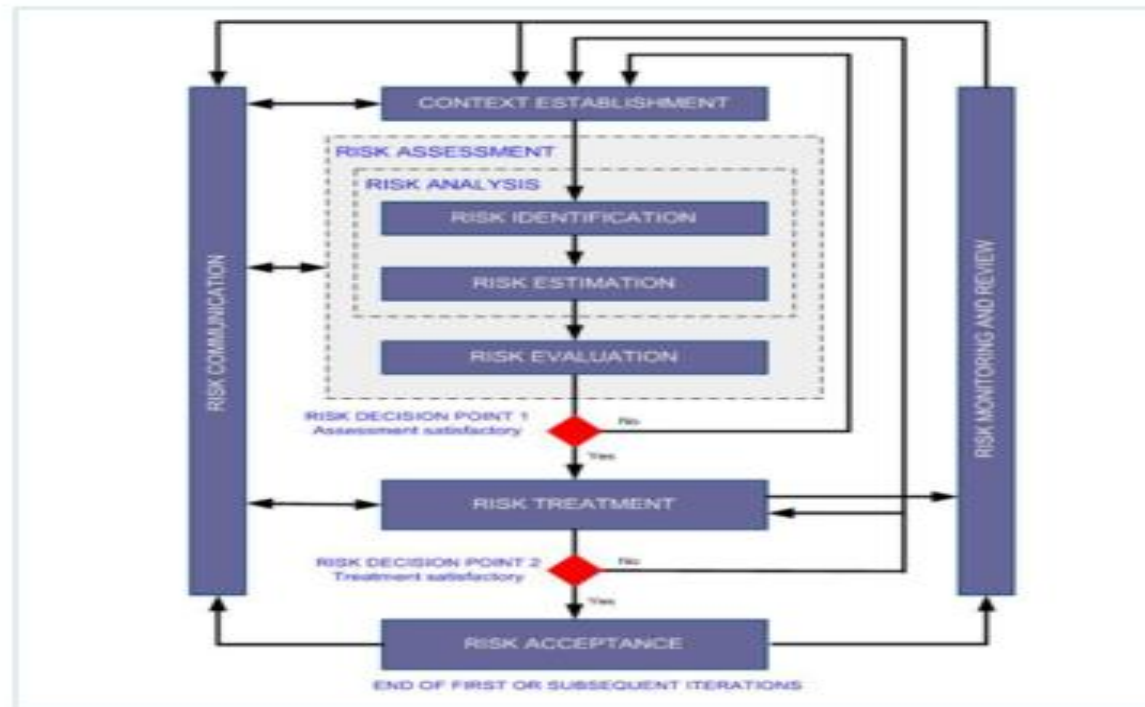
Concepts of IS risk management



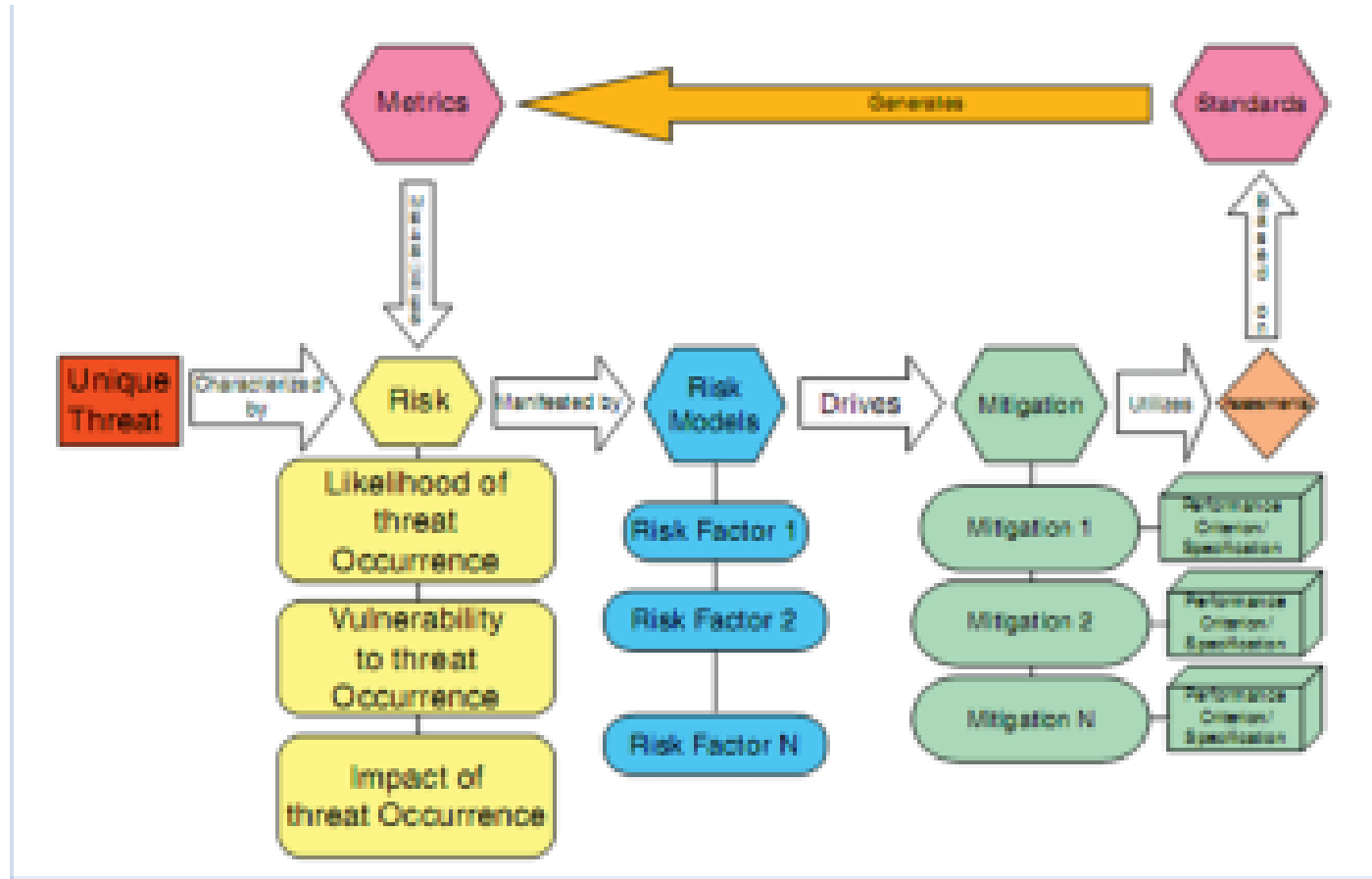
Security Risk Management process



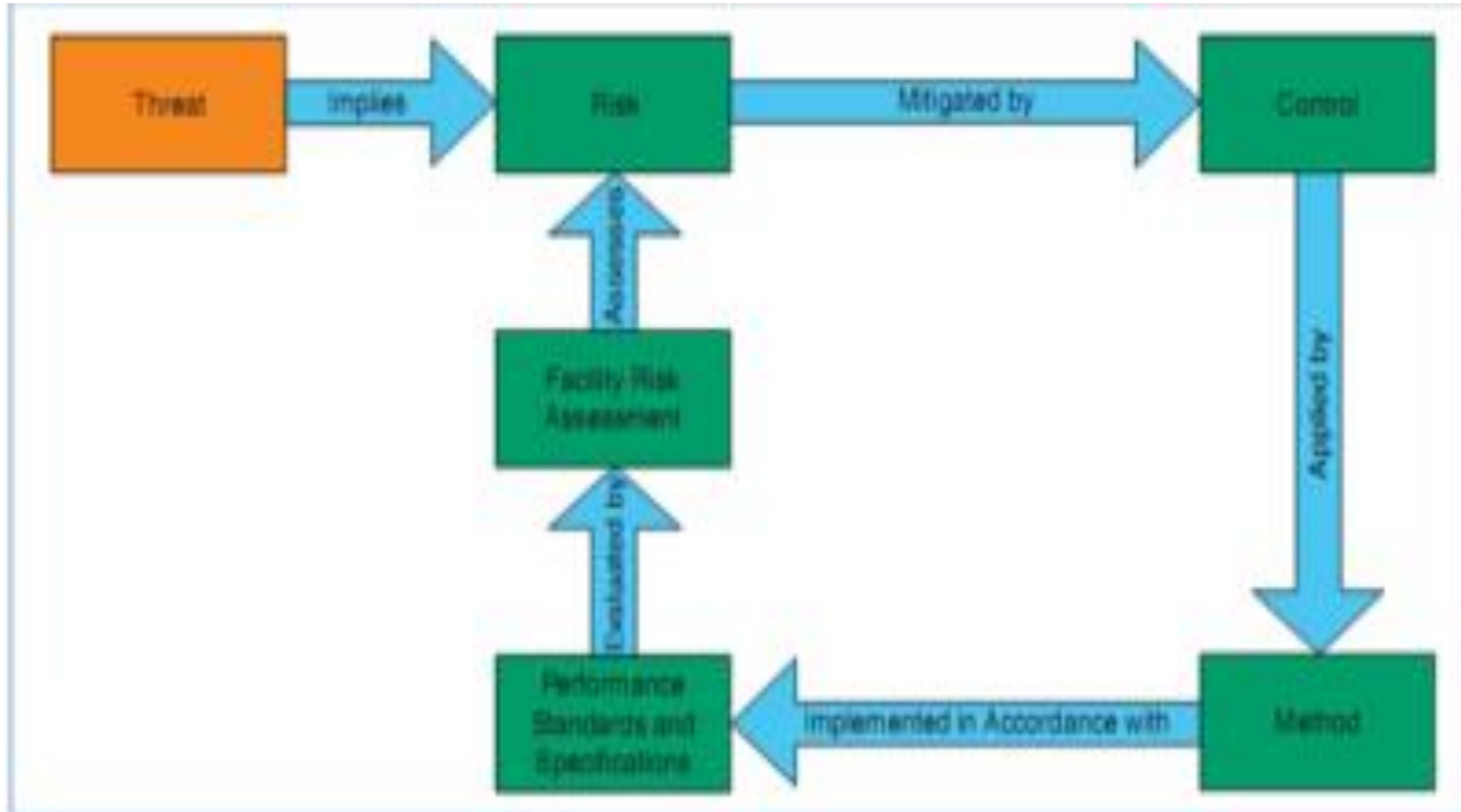
Information security risk management process



The security risk assessment process



The security risk mitigation process



Risk Analysis Process



Risk Assessment Process

